

HiDiTingV100 SDK 二次开发网络安全

注意事项

文档版本 00B01

发布日期 2025-06-05

前言

概述

HiDiTingV100 交付包为芯片解决方案交付包，主要包括芯片资料、硬件资料、SDK 软件包、软件参考设计以及软件资料等。用户可基于此芯片解决方案交付包，开发各种自定义的产品。

本文档从网络安全的角度，重点分析基于本交付包开发的产品在使用过程中，可能面临的与本交付包中 SDK 软件包相关的网络安全的威胁，同时，针对性地给出相应的解决方案。

产品版本

与本文档相对应的产品版本如下。

产品名称	产品版本
HiDiTing	V100

读者对象

本文档主要适用于以下工程师：

- 技术支持工程师
- 软件开发工程师

符号约定

在本文中可能出现下列标志，它们所代表的含义如下。

符号	说明
 危险	表示如不避免则将会导致死亡或严重伤害的具有高等级风险的危害。
 警告	表示如不避免则可能导致死亡或严重伤害的具有中等级风险的危害。
 注意	表示如不避免则可能导致轻微或中度伤害的具有低等级风险的危害。
 须知	用于传递设备或环境安全警示信息。如不避免则可能会导致设备损坏、数据丢失、设备性能降低或其它不可预知的结果。 “须知”不涉及人身伤害。
 说明	对正文中重点信息的补充说明。 “说明”不是安全警示信息，不涉及人身、设备及环境伤害信息。

修改记录

文档版本	发布日期	修改说明
00B01	2025-06-05	第一次临时版本发布。

目 录

前言.....	i
1 产品安全解决方案	1
1.1 安全架构.....	1
1.2 设备安全.....	2
1.3 安全启动.....	2
1.3.1 安全启动开关	2
1.3.2 安全启动流程	2
1.4 关键数据安全存储	3
1.5 驱动安全注意事项	3
1.5.1 Cipher 驱动	3
1.6 其他使用安全注意事项.....	4
1.6.1 JTAG 接口	4
1.6.2 代码安全注意事项	4
1.6.3 可维可测注意事项	4
1.6.4 OpenHarmony XTS 认证镜像烧写注意事项	4
2 结论.....	5
3 免责声明.....	6

1

产品安全解决方案

1.1 安全架构

1.2 设备安全

1.3 安全启动

1.4 关键数据安全存储

1.5 驱动安全注意事项

1.6 其他使用安全注意事项

1.1 安全架构

产品的网络安全是一个系统工程，涉及到整个产品的各个层面。

BrandyK100 版本可能涉及的威胁如下：

- 开机启动安全：

该部分主要涉及到系统启动过程中每一级镜像的校验机制。BrandyK100 提供安全启动方案，包含完整的启动信任链校验，信任根是 BootRom 和 efuse，先通过 BootRom 校验根公钥，再校验二级签名，之后依次校验 SSB 签名、APP 签名和 BT/DSP 签名。安全启动详细流程请参见“[1.3.2 安全启动流程](#)”。

- 系统升级安全：

系统升级方案存在的安全威胁是文件本身的合法性和完整性。SSB 和 Firmware 都可升级，采用数字签名方式对升级文件进行校验，SSB 和 Firmware 都有版本防回滚机制，其版本号分别与 efuse 中的版本进行认证，认证不通过将无法启动。

- JTAG 安全调试：

JTAG 调试功能默认开启，建议产品量产时将 efuse 中的 SWD 熔断使能（efuse 中 37 字节 bit[1]）、DSP JTAG 熔断使能（efuse 中 37 字节 bit[2]）烧写为 1 来关闭 JTAG 调试功能。

1.2 设备安全

基于安全性考虑，建议用户在最终产品中执行以下措施：

- 启用安全启动特性。
- 永久关闭 JTAG 调试功能。

1.3 安全启动

BrandyK100 支持安全启动。

1.3.1 安全启动开关

安全启动开关请参见《HiDiTingV100 安全启动 使用指南》中“安全启动配置”相关说明。

1.3.2 安全启动流程

步骤 1 BootRom 启动 SSB 流程：

BootRom 固化在芯片中，其自身不会改变，可以保证安全可信。BootRom 启动后，加载二级引导程序 SSB。

BootRom 校验及加载 SSB 的流程：

1. BootRom 读取 flash 中的根公钥，计算根公钥的 hash 值，与 efuse 中的根公钥 hash 进行比较，检查是否相同。如果相同，则认为根公钥可信，继续启动，否则终止启动。
2. BootRom 读取 flash 中的二级公钥的签名证书，用根公钥验证其中的数字签名，若验证通过，则继续启动，否则终止启动。
3. BootRom 读取二级签名证书中的 Subkey Category，与 efuse 中的 SubKey Category 进行比对，若一致，则继续启动，否则终止启动。

4. BootRom 读取二级签名证书中的 SubKey ID (0~31)，获取 eFuse 中 SubKey ID 掩码的第 ID 个 bit，该 bit 为 0，说明 SubKey 有效，则继续启动，否则终止。
5. BootRom 读取 flash 中的 SSB 镜像签名，用二级公钥进行验签，验签通过后验证 SSB 镜像的版本号，版本号正确则系统跳转至 SSB 启动，否则终止启动。

步骤 2 SSB 启动 APP 核镜像：

SSB 启动读取 flash 中的 APP 核的镜像签名，进行验签，验签通过后启动 APP 核，否则终止启动。

步骤 3 APP 启动 BT/DSP 镜像：

APP 核启动后依次读取 flash 中的 BT/DSP 核的镜像签名，进行验签，若都验签通过，则启动 BT/DSP 核，否则终止启动。

----结束

1.4 关键数据安全存储

用户记录账号、密码等保密信息时，需要保证这些数据的存储安全，所以要求这些数据在存储之前进行加密保护。

使用密钥派生时，派生出的硬件密钥软件不可见，无法直接访问。

1.5 驱动安全注意事项

1.5.1 Cipher 驱动

Cipher 驱动实现了标准的对称加密 AES、非对称加密 RSA、摘要算法 SHA256、密钥派生算法等，未使用任何私有算法。

使用时请注意：Cipher 密钥的长度越长，安全等级越高，因此建议使用 AES 128bit 及以上的密钥、RSA 2048bit 及以上的密钥，详细内容请参见《HiDiTingV100 安全软件开发指南》。

1.6 其他使用安全注意事项

1.6.1 JTAG 接口

恶意攻击者通过 JTAG 接口，可以篡改系统的任何配置，恶意破坏系统，因此建议用户采取措施：产品出厂时，配置 efuse，将 JTAG 永久关闭。

1.6.2 代码安全注意事项

代码错误引发的网络安全问题，一般都是源于最基本的代码规范问题，例如：指针越界、数组越界、入参不检查等错误。建议通过如下方法检查：

- 使用业界通用的代码健康扫描工具进行全覆盖扫描。
- 使用模糊测试工具，对所有 API 接口（包括设备驱动接口）进行全范围模糊测试。
- 使用业界通用的漏洞扫描工具对所使用的开源软件进行扫描。

1.6.3 可维可测注意事项

- 可维可测方案仅在调试时打开，Release 版本建议用户关闭。
- HSO 调试工具目前仅用于 SDK 问题定位时的调测日志打印。
- 可维可测接口详细使用方法请参见《HiDiTingV100 DFX 软件开发指南》。

1.6.4 OpenHarmony XTS 认证镜像烧写注意事项

OpenHarmony 版本从 3.2 升级 4.1 后，更新了 HUKS 根密钥保护方案，系统会生成新的根密钥。OpenHarmony 认证包含 HUKS 测试，因此 XTS 镜像烧写前，需要删除 3.2 版本在文件系统中创建的旧密钥，避免 4.1 版本 HUKS 使用错误的根密钥导致 XTS 用例失败。根密钥默认保存在“/user/app/user/maindata”中。OpenHarmony XTS 认证镜像准备步骤如下：

步骤 1 烧写 XTS 镜像前，检查文件系统中“/user/app/user/maindata”目录。如果已经存在该目录，则手动删除或格式化擦除 FS。

步骤 2 烧写 OpenHarmony XTS 镜像。

步骤 3 开机执行 XTS 用例，检查 HUKS 用例结果是否正常 Pass。

----结束

2 结论

BrandyK100 产品有必要基于安全威胁分析采取相对应的安全措施。以下安全原则供参考：

- 适度的安全：

安全设计是基于特定的安全危险场景分析，考虑到性能、成本、业务影响，决策采用最合适的安全措施。

- 最小授权：

根据职责的需要，给用户、维护人员、网络单元、程序、进程等授予最小的权限和资源。这样能减少潜在的安全风险。

- 主动协同防御：

及时识别恶意攻击源，并在攻击造成显著危害前自动删除恶意用户与网络之间的连接。也可以降低连接的带宽和服务质量，以尽量减少负面影响。

- 纵深防御：

纵深防御原则涉及到对威胁的多重防御。例如，当一个防御层不够时，另一个防御层将防止造成进一步破坏。

3 免责声明

客户应充分评估自身产品的网络安全要求（包括但不限于：在实际量产产品中，选择安全加解密算法、关闭不需要的调试接口和命令等），并承担最终责任。BrandyK100 产品提供的本注意事项文档帮助客户对自身产品进行网络安全加固。

BrandyK100 产品在本文档中所描述的部分功能使用到了密钥来提供安全机制，客户需要妥善生成、烧写、使用并管理密钥（包括但不限于非对称密钥、对称密钥等），否则将自行承担相关风险。